

SBOM Adoption: In Support of Better License Compliance and Software Security Practices

Photo by Fotis Fotopoulos on Unsplash.com

SBOM Adoption: In Support of Better License Compliance and Software Security Practices

Created on 2025-10-09 07:43

Published on 2025-10-09 15:00

Software Bill of Materials (SBOMs) have emerged as a critical tool for enhancing transparency, ensuring license compliance, and ensuring security within software supply chains. In this post, we delve into the role of SBOMs, discussing their importance in ensuring license compliance, mitigating cybersecurity risks, and facilitating regulatory adherence. We offer an overview of SBOMs, highlighting their importance in today's complex software landscape, including recent mandates such as U.S. Executive Order 14028 on Improving the Nation's Cybersecurity. Additionally, we examine industry-driven initiatives in advancing SBOM standardization and adoption. We conclude by offering actionable recommendations for effective SBOM implementation to help organizations achieve better transparency, mitigate risks, and build more resilient software ecosystems.

Historical Perspective

The concept of SBOMs has steadily evolved over the years in response to the growing complexity of software supply chains and the increasing importance of transparency and accountability in software development practices. Initially, SBOMs gained traction within highly regulated industries, such as aerospace, automotive, and defense, where stringent compliance requirements necessitated meticulous documentation of software components. However, it wasn't until the proliferation of open source software and the advent of cloud computing that SBOMs began to garner broader attention across diverse sectors. As software ecosystems expanded and dependencies proliferated, the need for standardized SBOM frameworks became increasingly apparent, laying the groundwork for industry-driven initiatives aimed at promoting SBOM adoption.

The Linux Foundation launched the SPDX (Software Package Data Exchange) project in 2009, a significant milestone towards SBOM standardization. SPDX aimed to develop a common standard for documenting and sharing SBOMs, fostering interoperability and collaboration. Concurrently, initiatives such as OWASP CycloneDX emerged to address the need for lightweight, machine-readable formats for SBOMs, further advancing the cause of SBOM standardization.

SBOM momentum received a boost with the issuance of the United States' Executive Order (EO) 14028 on Improving the Nation's Cybersecurity in May 2021. This EO underscored the critical importance of enhancing software supply chain security in light of escalating cyber threats and directed federal agencies to adopt SBOMs for software procurement. It called for the establishment of minimum elements for SBOMs (discussed in a later section) and laid the groundwork for broader adoption through collaborative efforts. As a result, SBOMs have transitioned from being used in specific, highly regulated industries within a narrow context to a broader component of legislative and regulatory efforts aimed at safeguarding software supply chains and bolstering national cybersecurity posture, regardless of industry type or technology domain.

SBOM Basics

At its core, an SBOM serves as a comprehensive, machine-readable inventory detailing the constituent software components within an application, a system, or a software stack. Analogous to a bill of materials in traditional manufacturing, an SBOM offers transparency and visibility into the software supply chain, facilitating robust software governance and risk management practices. An SBOM typically comprises the following five key elements: component inventory, origin information, dependency relationships, vulnerability intelligence, metadata, and annotations. We briefly explain each of these elements in the following subsections.

1. **Component Inventory:** The component inventory is a comprehensive list of all software components, including both open source and proprietary components, along with their respective versions and dependencies.
2. **Provenance Information:** The provenance information includes metadata covering the origin and ownership of each software component, including licensing terms, copyright attributions, and contributors.
3. **Dependency Relationships:** The dependency relationships are hierarchical relationships that delineate dependencies between software components, facilitating traceability and impact analysis.
4. **Vulnerability Intelligence:** Vulnerability intelligence encompasses detailed information regarding known security vulnerabilities associated with each software component in the component inventory. The goal of this

intelligence is to enable proactive risk mitigation and vulnerability management.

5. **Metadata and Annotations:** Metadata and annotations are additional contextual information that enrich the SBOM, such as build instructions, release notes, and compliance attestations.

Criticality of SBOMs

SBOMs play an important role in both license compliance and cybersecurity. From ensuring adherence to applicable licenses (including both commercial and open source licenses) to improving defenses against cyber threats, SBOMs provide organizations with insights into their software components. In the following subsections, we will go further into detail on the role SBOMs play from both a license compliance and security perspective.

License Compliance

From the standpoint of license compliance, SBOMs offer a strategic advantage by providing comprehensive insights into the web of software components that underpin organizational operations. In today's environment, where organizations depend on open source software for anywhere between 20% to 85% of their software stack, it is highly critical to catalog open source and proprietary software assets, understand license obligations, and have a plan to execute and fulfill these obligations. SBOMs empower license compliance teams to mitigate legal, reputational, technical, and financial risks associated with license violations. The absence of SBOMs exposes organizations to many license compliance pitfalls, necessitating manual and error-prone methods of software asset tracking that undermine operational efficiency and expose organizations to unnecessary risks.

Security

In the domain of cybersecurity, SBOMs emerge as a critical asset in improving organizational resilience against evolving threats within the software supply chain. By proactively identifying and addressing vulnerabilities in third-party components, SBOMs serve as early warning systems, enabling organizations to mitigate security risks before they escalate into full-blown breaches preemptively. SBOMs facilitate streamlined incident response and patch management efforts, equipping organizations with the agility and foresight needed to safeguard critical assets and avoid exploits of security vulnerabilities.

Legislative Context and SBOM Minimum Elements

Against the backdrop of escalating cyber threats and regulatory scrutiny, legislative efforts such as the United States' EO 14028 (previously mentioned) highlight the strategic importance of enhancing software supply chain security. Central

to this executive mandate is the directive to delineate minimum elements for SBOMs, positioning SBOMs as linchpins in fostering transparency and accountability across the software development lifecycle. EO 14028 highlighted the following minimum elements required for SBOMs:

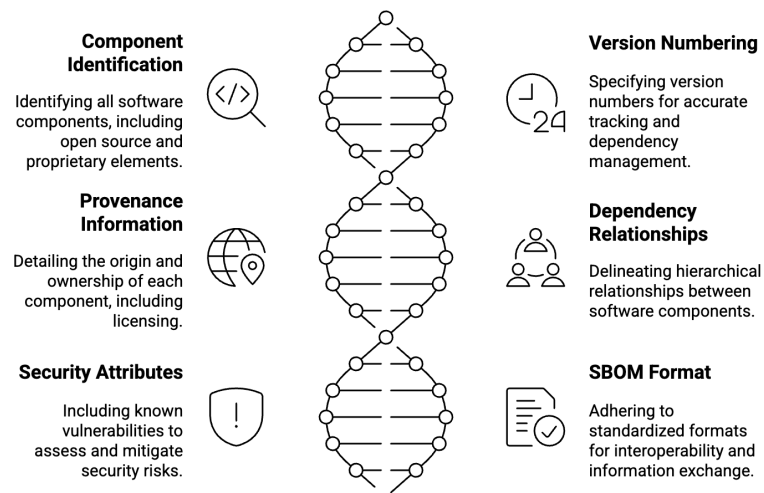
1. **Identification of software components:** SBOMs should identify each software component within a system or application, including both open source software components and proprietary/third-party commercial components.
2. **Version numbering:** SBOMs should specify the version numbers of each software component to ensure accurate tracking and management of dependencies.
3. **Provenance information:** SBOMs should contain metadata detailing the origin and ownership of each software component, including licensing information, copyright attributions, and contributors.
4. **Dependency relationships:** SBOMs should delineate the hierarchical relationships between software components, including dependencies and interactions between different modules or libraries.
5. **Security attributes:** SBOMs should include information about known security vulnerabilities associated with each software component, enabling organizations to assess and mitigate security risks effectively. Security information is sourced from a CVE (Common Vulnerabilities and Exposures) database, which contains publicly disclosed security vulnerabilities.
6. **SBOM format:** SBOMs should adhere to a standardized format or schema to facilitate interoperability and the exchange of information between different organizations and systems.

These minimum elements of an SBOM serve as a foundational framework for promoting transparency, accountability, and security within software supply chains, enabling organizations to better understand and manage the risks associated with third-party software components.

Industry Initiatives

Industry alliances and consortia, including the Linux Foundation's SPDX project and OWASP's CycloneDX, have coalesced around the importance of SBOM standardization, supporting tools and adoption. These collaborative endeavors serve as catalysts for innovation and knowledge sharing, incubating best practices and frameworks aimed at facilitating the integration of SBOMs into diverse software ecosystems. These initiatives have paved the way for accelerated SBOM adoption, positioning organizations for improved security and license compliance practices and outcomes. In the following subsections, we will explore further the efforts of the Linux Foundation, Open Web Application

Essential Elements of SBOMs



Ibrahim Haddad , PhD
IbrahimAtLinux.com

Figure 1:

Security Project (OWASP), and the National Telecommunications and Information Administration (NTIA) in their support for creating SBOM standards, supporting tools, and promoting and advocating the adoption of SBOMs.

1. **Software Package Data Exchange (SPDX) Open Standard:** The Linux Foundation's SPDX (Software Package Data Exchange) open source project has been at the forefront of standardizing SBOMs and promoting their adoption across the software industry since 2009, more than 11 years earlier than EO 14028. The Linux Foundation has demonstrated incredible leadership and recognized the need for a common framework to facilitate the exchange of software component information in its effort to support open source license compliance practices. SPDX brings together organizations from various industries to develop standardized formats and tools for creating, sharing, and analyzing SBOMs. Through the typical open source collaborative effort and community engagement, SPDX has established a robust ecosystem of tools, resources, and best practices to support SBOM adoption and implementation. By providing guidance, developing specifications, and fostering collaboration, the Linux Foundation, through its SPDX effort, has played a crucial role in advancing SBOM standardization, enabling organizations to enhance transparency, streamline license compliance, and improve security within their software supply chains.
2. **OWASP CycloneDX SBOM Standard:** CycloneDX is an initiative under the Open Web Application Security Project (OWASP) that has been instrumental in promoting SBOM standardization and adoption within the cybersecurity community. With a focus on lightweight, machine-readable formats for SBOMs, CycloneDX aims to simplify the process of generating and sharing software component information. By developing open standards and tooling for creating, validating, and consuming SBOMs, CycloneDX has empowered organizations to integrate SBOMs into their development and security workflows seamlessly. CycloneDX has fostered a vibrant ecosystem of tools and resources to support SBOM adoption and implementation and continues to contribute to the overall resilience of the cybersecurity landscape, helping organizations mitigate risks and address vulnerabilities effectively.
3. **NTIA Advocacy for SBOMs:** The National Telecommunications and Information Administration (NTIA) has played a pivotal role in spearheading SBOM advocacy efforts, leveraging its position as a key agency within the U.S. Department of Commerce to drive collaboration and consensus-building. Recognizing the critical importance of SBOMs in enhancing software supply chain security and resilience, NTIA has actively engaged with organizations from across the public and private sectors to promote SBOM adoption and standardization. Through convening working groups, hosting public forums, and facilitating discussions, NTIA has fostered a collaborative environment where organizations can exchange insights, share best practices, and develop consensus around SBOM frameworks.

and guidelines. By championing SBOM advocacy efforts, the NTIA has demonstrated a commitment to advancing cybersecurity initiatives and safeguarding the integrity of software supply chains, ultimately contributing to a more secure and resilient software ecosystem.

Recommendations for Effective SBOM Implementation

To harness the full potential of SBOMs, organizations must embrace a strategic approach to implementation, driven by automation and strategic utilization. In this section, we share some of the recommended practices for an effective SBOM implementation.

1. **Establish clear policies and procedures:** Organizations should develop comprehensive policies and procedures outlining the generation, maintenance, and utilization of SBOMs throughout the software development lifecycle. Such policies and procedures (or processes) are typically part of a significant effort defining the organization's internal compliance and security infrastructure.
2. **Clear roles and responsibilities:** Organizations need to ensure that all of their staff are aware of their roles and responsibilities regarding SBOMs, and at a broader level, regarding the practices to ensure compliance with applicable software licenses and software security guidelines. Organizations have used various ways to structure their teams responsible for fulfilling this function. Some companies have opted for a centralized team.. Other companies have opted for a cross-functional team that consists of a dedicated Open Source Compliance Officer who has access to various individuals and teams (DevOps, Engineering, Legal) that contribute to the compliance effort without being part of a centralized team. For a detailed discussion on setting up an open source license compliance infrastructure, we recommend "Open Source License Compliance in the Enterprise", 2nd Edition, published by the Linux Foundation.
3. **Automate SBOM generation:** Organizations should integrate SBOM generation as part of their continuous integration and delivery (CI/CD) pipelines to create an SBOM with each software build. SBOM functionalities are embedded as part of Software Composition Analysis (SCA) tools that support software development teams in ensuring open source license compliance and improving the security of their code. Among their core functionalities, SCA tools perform automated scans on source codebases and help identify open source components, their license, flag any known vulnerabilities, and generate an SBOM of the scanned code.
4. **Enrich the SBOM with metadata and vulnerability information:** Organizations should enhance the production of their SBOMs with additional metadata about software components, such as version numbers, dependencies, license, and known security vulnerabilities associated with each software component.

5. **Integrate SBOM production and management into compliance and security practices:** Organizations should incorporate SBOMs into their open source license compliance and security practices to demonstrate robust governance and risk management.
6. **Educate and train staff:** Organizations need to provide training and education to staff involved in license compliance and security practices. The Linux Foundation offers a wide range of free training courses on licensing compliance and software security that are available at your fingertips.
7. **Regularly update and review SBOMs:** Organizations need to maintain their SBOMs regularly as the use of software components changes or new vulnerabilities are discovered. Typically, organizations establish a process for monitoring changes and ensuring that SBOMs accurately reflect the current state of deployed or used software assets. Maintaining compliance and security is a continuous effort that requires discipline and a commitment to incorporating these activities into existing practices. One such practice is to institute recurring open source risk audits based on a predefined interval of time for all source code, which will result in up-to-date SBOMs.
8. **Collaborate with industry initiatives:** Organizations should engage with and participate in industry initiatives working on SBOM standardization efforts, such as the Linux Foundation's SPDX project and OWASP CycloneDX. There are many benefits to such participation, including collaborating with peers to share best practices and contribute to the advancement of SBOM adoption.
9. **Monitor and evaluate effectiveness:** Organizations should implement mechanisms to monitor the effectiveness of their SBOM implementation, such as tracking license compliance with SBOM policies, assessing the impact on security incident response times, and measuring improvements in vulnerability management processes. Organizations often rely on these insights to refine and improve their SBOM practices over time.

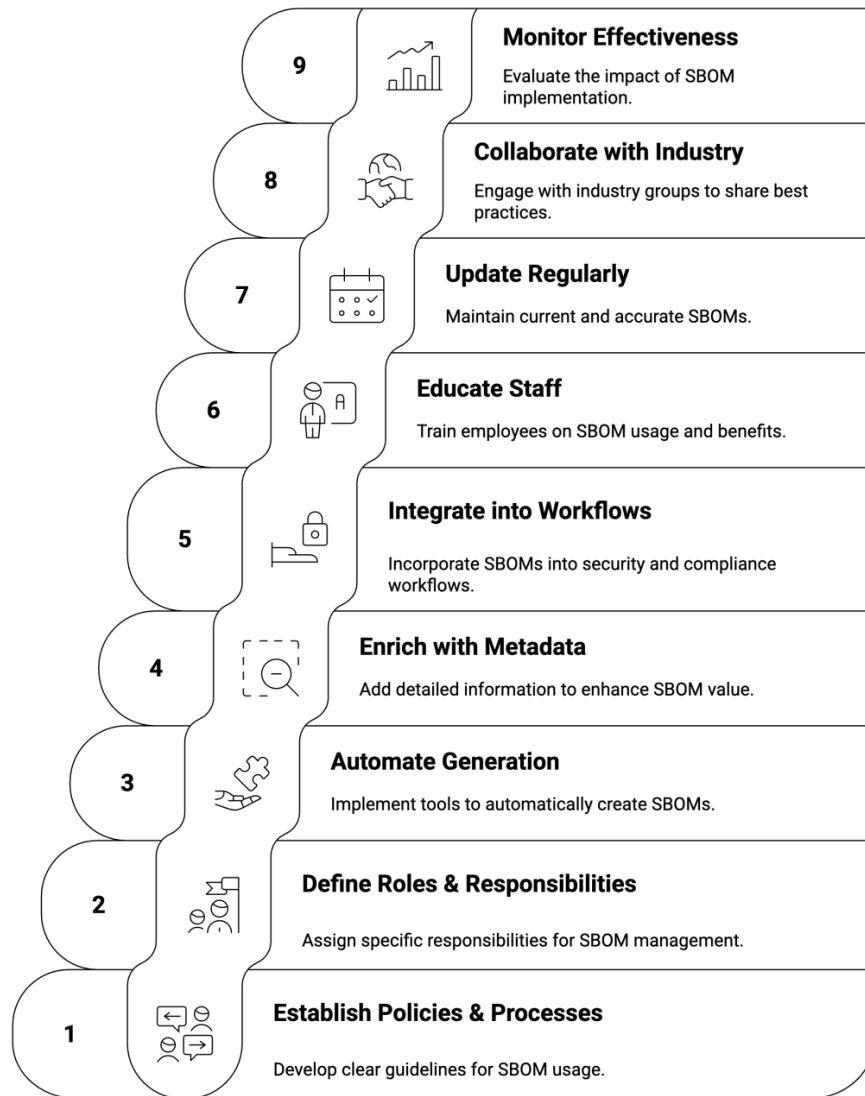
By following these recommendations, organizations can effectively implement SBOMs to enhance transparency, license compliance, and security across their software supply chain.

The next frontier is SBOM management, which covers versioning, updating, monitoring, storage, and workflow integration. More on that in a future post!

About the Author

Dr Ibrahim Haddad is currently Head of Infotainment at Volvo Cars. He is widely recognised for his leadership in building and scaling Open Source Program Offices (OSPOs), having founded and directed them across multiple organisations, and advised both corporations and NGOs on open source strategy and governance. Previously, he served as Vice President of Strategic Programs

Recommendations for Effective SBOM Implementation



Ibrahim Haddad , PhD
IbrahimAtLinux.com

Figure 2:

(AI) at the Linux Foundation, where he was the Executive Director of LF AI & Data and the Founding Executive Director of the PyTorch Foundation. Before the Linux Foundation, Dr Haddad served as Vice President of R&D and Distinguished Engineer at Samsung Research Silicon Valley. His career includes R&D technical and leadership roles at Ericsson Research, Open Source Development Labs, Motorola, Palm, and Hewlett-Packard. He holds a PhD with honours in Computer Science from Concordia University (Montréal, Canada).

[LinkedIn](#) - [Website](#)